

SentinelUEBA

AI-Powered Behavioural Anomaly Detection for Cybersecurity

Honeywell Technologies Campus Connect · Problem 4

Learn normal, flag deviation, explain every alert — no signatures.

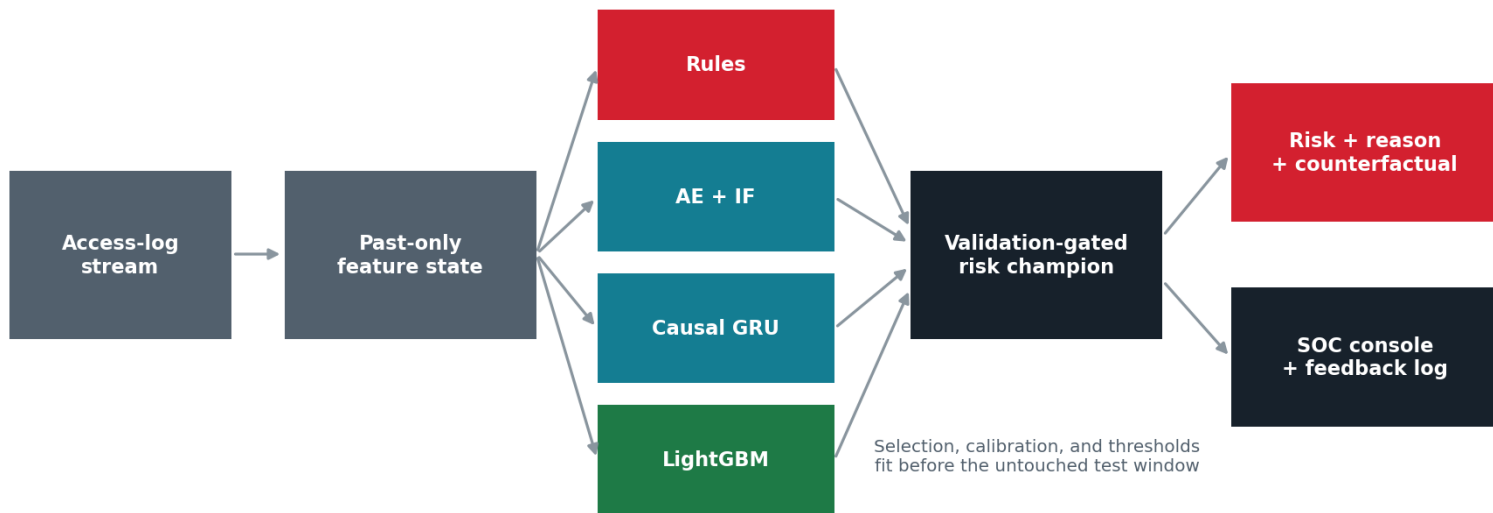
The problem

Signatures can't see novel or low-and-slow intrusions

- Every login, API call and device connection leaves a behavioural trail.
- Signature-based security (fixed rules, known hashes) misses novel and slow attacks.
- **Behavioural anomaly detection: learn what 'normal' looks like per entity, flag deviation.**
- Domain-agnostic: same ML protects a utility network, factory edge devices or IT/OT.
- Hard parts: extreme class imbalance, concept drift, cold-start, and explainability.

Architecture

A layered ensemble — no single model catches everything



Coverage

Each behaviour is matched to the right detector

- Impossible travel -> geo-velocity physics rule (explainable, ~0 FP)
- Brute force / stuffing -> failed-auth burst + IP fan-out rules + AE
- Device spoofing -> fingerprint-mismatch rule
- Lateral movement -> GRU sequence AE + session-breadth novelty
- Low-and-slow exfiltration -> off-hours byte z-score + AE
- Attack typing -> LightGBM (tabular -> boosting beats deep nets)

The three hard problems

Where most solutions hand-wave

- **Class imbalance** — unsupervised core needs no labels; PR-AUC 0.994 at 2.0% base rate; report F1, not acc
- **Concept drift** — expanding baselines + Page-Hinkley re-baselining; benign insider drift FP-rate 0.00%.
- **Cold-start** — history-free rules + peer-group tolerances; new-entity attack recall $69\% \pm 12\%$ across 5 seeds

Results

Held-out window · extreme imbalance

Detection ROC-AUC	0.999
-------------------	-------

Detection PR-AUC	0.994
------------------	-------

Top-1% budget (precision-first)	100% prec · 47% recall · 0 FP
---------------------------------	-------------------------------

Top-2% budget (coverage)	99% recall · 74% prec
--------------------------	-----------------------

Attack-type macro-F1	0.947
----------------------	-------

Operational risk vs classifier	0.999 vs 0.999
--------------------------------	----------------

Top-1% is precision-first; the analyst picks top-2% when coverage matters. Thresholds fixed on validation before test.

Analyst experience

A ranked queue with evidence, history, and feedback

- Ranked alert queue with a plain-English reason on every alert.
- Entity drill-down: risk timeline, channel scores, fingerprint & geo history.
- Analyst dispositions are persisted and consumed on the next auditable refresh.
- **Past-only feature state is compatible with streaming ingestion; the benchmark is batch replay.**
- **Every result includes provenance, assumptions, and known limitations.**

SentinelUEBA — learn normal, flag deviation, explain every alert.

Evidence boundary

Strong prototype evidence, stated with the right level of confidence

- Synthetic access logs are required for labelled user, service-account, and device events.
- **Held-out evidence: PR-AUC 0.994; attack-type macro-F1 0.947.**
- **Evaluation is chronological with purge gaps, validation-fitted policies, and an untouched test window.**
- **Metrics demonstrate behaviour under documented simulation assumptions, not production guarantees.**
- Next validation: parameter-shifted campaigns, public identity logs, and Honeywell-domain replay.

Path to deployment

A defensible prototype with an explicit next step

- Connect the same causal state engine to Kafka or an equivalent event bus.
- Validate thresholds and alert budgets with analyst-labelled Honeywell-like telemetry.
- Add model registry, checkpointed feature state, shadow deployment, and approval gates.
- Extend lateral-movement validation with an entity-resource graph ablation.
- Keep the analyst contract: ranked risk, reason codes, counterfactuals, and an audit trail.